

来源标注不完美时，Agent 数据流策略的安全—可用性边界

Security–Utility Tradeoffs under Imperfect Source Annotations in Provenance-Aware LLM Agents
研究设计草案 · 2026-10-11 · 仅文档；新实验均为 PLANNED/UNRUN

1. 研究问题、现有证据与文献定位

问题：如何在来源标注不完整、过时或错误时，维持 Agent 数据流策略的安全性与可用性？将“正确传播已有标签”与“标签具有可靠语义”分开。目标是测量标注失真如何改变泄露、正常任务完成和误阻断，并识别哪些失真可以在不引入语义判断器的情况下发现。

PR #5 已冻结于 5c2b86c：255 个文件逐一哈希，含 V1.10、28 个任务和完整原始结果。唯一任务的已观测结果如下；14 个攻击、12 个正常，2 个控制不入分母，三次重复不构成新任务。

策略	ASR ↓	TCR ↑	FPR ↓
粗粒度	8/14	3/12	9/12
当前精细化	11/14	8/12	4/12
保守精细化	4/14	7/12	5/12

保守策略在这批任务上优于粗粒度，并相对当前精细化多阻断 7 个攻击、增加 1 个误阻断。这是作者构造的局部权衡证据，不是最优策略或泛化证明。错误 PUBLIC 仍可泄露；历史 36 项模型 UNRUN 不能证明模型防御效果。

相关工作与待核实差异。 已读取以下指定版本原文，不能把已有能力当作本项目创新：

- **CaMeL [1]**：受限解释器、依赖图、细粒度来源/reader 能力和工具执行前策略；§ 9 已讨论策略维护与降密疲劳。我们的候选差异是显式干预标注错误及 Schema 演变，测量曲线；不是首次实现来源追踪。
- **FIDES [2]**：§ 4.2 已支持结构化工具结果的节点/字段标签，§ 5 支持隐藏、受约束 reveal 和基于类型的放行。不能宣称“字段 Schema + 有限放行”本身新颖。
- **APPA [3]**：有上下文分支、调用范围授权和受信 sanitizer；§ 8 明确依赖声明的合同标签，指出未声明写合同的洗白路径。声明可信性问题已有先例。
- **FlowSeal [4]**：代码级来源标签和输出边界控制，语义降密由隔离判断器完成。我们的主实验固定显式转换，研究标注错误，不把模型语义判断效果混入。

贡献候选，不是已验证创新：一个标签失真干预协议、按错误率/方向分层的安全—可用性曲线，以及对错误可信输入无法仅靠完整性修复的边界分析。初步检索不是穷尽综述；须继续核查直接近邻的实验与工件，未复现这些系统，不比较官方分数。

2. 威胁模型与来源可信性的边界

保护对象：由独立任务契约定义的敏感数据，到未经授权 HTTP 或模型上下文的显式传播。合法公开投影必须有实际执行和接收证据。真假敏感性不得输入待评估的可部署防御；单列的 oracle 仅测理想上界。

情况	可控内容与权限	实验解释
配置失误/老化	合法发布者漏标、反向错标、错用旧版本；签名仍有效	故障注入，不能称为签名伪造
未授权元数据攻击	不可信工具内容自称 PUBLIC、伪造授权、重放已撤销版本	新增威胁面：可检验授权真实性
针对性错误标注	在规定错误预算内把目标敏感叶字段、父容器或整源标为 PUBLIC	故障与攻击联合作用；不假设攻破发布密钥

攻击者可选择工具和受支持转换、控制不可信文本及指定的声明通道；不能修改运行时、验证器、评估真值或独立接收端。合法声明者可以犯错，**不把“发布者已认证”当成“分类一定正确”**。分类发布者与放行审查者的权限分开，并明确各自可能犯错的条件。

保留现有边界：受控 AgentPort/工具请求，不是任意 Python 沙箱；普通未包装字符串、第三方内部转换、模型改写、隐式/时间通道不受本研究显式保证覆盖。攻击数据完全合成，HTTP 固定本机；外部网络拒绝不得计防御成功。

不可识别性边界。若敏感与正常两个世界对防御呈现相同值、类型、来源、版本和合法 PUBLIC 声明，仅依赖这些输入的判定无法区分两个世界。签名、内容哈希或 Schema 合法性不能补足缺失的语义证据。这是限定输入下的论证，不是对完整系统的非干扰证明。

Schema-Aware Source Trust 的候选设计轴，尚未选择实现：

- 版本与结构：**验证源 ID、发布者、Schema ID/摘要、版本和撤销状态；新增/缺失字段、类型变化、未知版本记为不确定。PUBLIC 父容器不自动授权新子字段；数组项与规范化路径必须有明确作用域。独立版本/撤销目录属于 TCB；目录同样过时不受此检查保护。
- PUBLIC 权限：**区分 Schema 发布与放行权限；声明由不可信内容携带时不能自行生效。授权绑定来源实例、精确投影、输出目标与有效期；拒绝跨源/跨 sink/撤销后重放。重新检查发送时的内容摘要，防止检查与使用之间变化。
- 冲突与有限放行：**拒绝优先；显式拒绝不能被低权限允许覆盖。未知兄弟字段不污染已验证公开叶投影，但整个不确定容器不能因一个公开叶而放行。默认值、结构标签和放行记录分别审计。
- 审查：**可选的独立分类证据或有限人工审查；不得读取评估真值。零预算与审查失败必须保留。合法签署的错误 PUBLIC、同类型字段语义漂移仍可能不可检测。

先测无审查边界，再决定是否实现最小的版本/字段变化检查；不预设完整授权系统或自动语义分类器。

3. 拟议实验：正确标注、随机失真与适应性攻击

所有以下数字是设计预算，不是已采集数据。拟准备 120 个独立来源家族，开发集 60、外部作者保留集 60；每家族一对攻击/正常任务，共 240 任务。同源任务、变体、错误种子和重复均属于一个统计簇。保留材料尚未收到；不能把旧 28 个任务改名为保留集。

每家族含文件或受控工具来源、至少 20 个叶字段，公开/敏感真值平衡；嵌套、列表、可选字段及五类已支持显式路径预先分层。使用扫描器不命中的虚构敏感载荷，并另设扫描与传输校准。冻结真值、源内容、路径、转换、成功契约和分割；各组共享这些输入。故意改变的只有标注与可信性处理。

实验	预先固定的干预	主问题
E0 正确声明	零错误；公开与敏感成对任务	基础防御与正常完成能力
E1 随机错标	敏感→公开、公开→敏感、双向三个面板	错误率变化时 ASR/TCR/FPR 的形状
E2 完整性/老化	省略字段、增字段、旧版本、类型变化、冲突；单因素起步	结构检测能补救哪些失真，成本是什么
E3 针对性错标	与 E1 同预算，优先攻击输出依赖的敏感字段，再试父容器/整源 PUBLIC	小比例错误是否造成集中泄露

E1 的目标比例为 0、5%、10%、25%、50%、100%，种子 17、29、43、71、101。分别定义敏感→公开错误数/真实敏感叶数和公开→敏感错误数/真实公开叶数；跨家族池抽样取整，同时报告实际分子/分母，不把目标比例当实际比例。固定每种子下的字段随机排名，高比例取同排名的更长前缀；排序不得按真值错误后结果调整。

零错误只设一个条件，其余五比例各三方向面板，共 16 条件。现有三策略的拟议 E0/E1 主预算为 $240 \times 16 \times 5 \times 3 = 57,600$ 条执行观测，另加控制；不是 57,600 个独立攻击。预算不是功效保证；先以开发集 pilot 检查可运行性和方差，估计可检测差异，最终预算在正式采集前锁定，不用效果决定扩样。统计条件不足则标探索性。

E3 攻击者可知策略和字段结构，开发适应最多每任务 20 次本机查询；保留集每契约只执行冻结攻击一次。父 PUBLIC 或整源 PUBLIC 的预算按影响的所有敏感/公开叶字段计费，不能用“改一个父标签”隐藏大规模错误。两类攻击的查询数、实际失真率和适应过程完整导出。

比较原则：三种已冻结策略是必需基线；Schema 严格模式、有限审查模式只在设计评审后选定，不用新机制替换失败基线。所有组有同一执行器/扫描器/接收端、源声明、任务及运行顺序随机化。若使用审查，另设零预算和正确真值 oracle 上界：oracle 仅测理想上界，不冒充可部署防御；真实有限审查的成本、错误和未答复另记。

E2/E3 和审查预算做分阶段正交扩展，不立即跑所有维度的笛卡尔积。其目标变化、计费规则、输入哈希必须在各阶段运行前冻结。

4. 分析协议、独立验证与机制决策

指标与观测：ASR=实际敏感输出送达数/有效攻击观测数；TCR=正常契约确有工具执行、匹配接收及回执的完成数/有效正常观测数；FPR=正常任务被中间件阻断数/有效正常观测数。泄露匹配规则、编码和片段判据在契约中先冻结；未知语义重构不计成功防御。另报 TP/FP/TN/FN、Precision/Recall。缺少观测为 UNRUN，不能计 HELD；控制、未支持转换与无效证据分别排除并公布数量。

每格报告 eligible/observed/excluded、指标分子/分母和唯一家族数。缺失时另给敏感性界：泄露数/eligible 至（泄露数+缺失数）/eligible，不能用低覆盖率宣称零泄露。正常完成也给相应缺失界；对完整观测对报告配对差异，完整案例分析的选择偏差单列。

绘制每错误方向的 ASR(p)、TCR(p)、FPR(p)，不事先要求单调，也不拟造尚未测得的曲线。按来源家族重采样，保留其所有任务、错误种子、策略和变体，拟用 10,000 次配对簇 bootstrap 给差异区间；主对照为当前与保守精细化，主终点是敏感→公开面板的 ASR 曲线面积差，TCR 为必要的可用性终点，其余探索性。六比例点的梯形面积只是网格摘要，不是真实部署错误率期望；不跨面板平均。模板共享时上提聚类单位。不以重复数代替样本量，现有 14 个攻击不支持功效结论。

在相同失真面板和审查预算下判断观察到的非支配选择，给出泄露减少、正常完成损失与审查工作量；不能据此声称一个策略普遍最优。额外耗时只有同契约配对 No Defense 校准时才计算，否则 null；源校验、传播、边界门禁和审查分别计时，不把网络或模型延迟归入防御。审查另报请求比例、处理时间、错误及等待超时；拒绝全部输出只作负面极端控制，不作成功基线。

独立验证工作线：外部作者在实现冻结后提交攻击和真值契约；第三方独立复跑并报告实现/数据摘要。Agent-Dojo [5] 需固定版本、适配差异和官方成功判据；当前仅有未执行材料。真实 Agent 需可用凭据、核实模型和费用预算，分开测多轮攻击采纳与外泄；直接/间接注入分层。两条线补充主实验，不替代来源失真曲线；未运行就保留 UNRUN。

何时新增机制：先审核上述威胁假设、文献差异和实验单位，再冻结新数据与候选。若最小结构校验只减少版本/字段遗漏，而不能改善合法错误 PUBLIC，照实限定结论；若收益来自全拒绝或 oracle，拒绝作为可部署贡献。若保留集反例导致再调实现，该集降为开发集，重新取得独立材料。可以先交付可信的测量/边界分析论文，不必承诺一套新防御。

原始参考文献（本次实际读取，版本固定；没有复现其防御）：

- [1] Debenedetti et al. Defeating Prompt Injections by Design. arXiv:2503.18813v2, § 5.2–5.4、§ 9.2–9.3。
- [2] Costa et al. Securing AI Agents with Information-Flow Control. arXiv:2505.23643v1, § 2.2、§ 4.1–4.4、§ 5。
- [3] Kravchenko et al. Agentic Permissions Policy Algebra for Taint Confinement in LLM Agents. arXiv:2607.24625v1, § 5、§ 8（PDF 第 9 页）。以 PDF 标题为准，索引标题不同。
- [4] Shim et al. Confuse the Model, Control the Flow: Understanding and Mitigating Privacy Leakage from LLM Agents with Information Flow Control. arXiv:2609.14003v1, § V-A–B。
- [5] Debenedetti et al. AgentDojo: A Dynamic Environment to Evaluate Attacks and Defenses for LLM Agents. arXiv:2406.13352v1, § 2–3。